

INTRODUCTION

TO

SOAR

&

EDR



R&K InfoTech

A Better Place To learn

BY

KUMAR RAJA REDDY T

SOAR and EDR

What is SOAR?

SOAR stands for **Security Orchestration, Automation, and Response**.

It's a platform that integrates security tools, automates repetitive tasks, and coordinates responses to incidents across systems and teams.

In short, **SOAR helps SOC teams do more, faster, with fewer errors.**

Why is SOAR Needed?

1. Alert Overload

SOCs often face **hundreds or thousands of alerts per day**. SOAR helps filter, correlate, and automate triage.

2. Skill Gaps & Burnout

SOAR reduces manual effort and analyst fatigue by automating repeatable, time-consuming processes.

3. Faster Response

Time is critical in incident response. SOAR enables **automated playbooks** for consistent, fast actions—reducing **MTTD** (mean time to detect) and **MTTR** (mean time to respond).

4. Tool Integration

Security tools often work in silos. SOAR acts as the **glue**, connecting EDR, SIEM, firewalls, ticketing, threat intel, and more.

What Can Be Automated with SOAR?

Here are common SOAR automation use cases:

1. Alert Triage & Enrichment

- Automatically enrich alerts with:

SOAR and EDR

- IP/domain reputation (VirusTotal, AbuseIPDB)
- WHOIS and geo-IP lookups
- Threat intelligence feeds (MISP, commercial TI)
- Asset inventory and vulnerability data
- Prioritize alerts based on severity, asset value, and past history



2. Email & Phishing Analysis

- Automatically analyze suspicious emails:
 - Extract and scan attachments or URLs
 - Detonate files in a sandbox
 - Parse headers and detect spoofing
- Based on results, delete the email from multiple inboxes or quarantine it

□ 3. Incident Response Actions

- Quarantine endpoints via EDR
- Disable or lock compromised AD accounts
- Block malicious IPs/domains in firewall or proxy
- Isolate network segments
- Initiate password resets



4. Ticketing & Communication

- Auto-create tickets in systems like Jira or ServiceNow
- Populate investigation data into standardized templates

SOAR and EDR

- Notify teams via Slack, Teams, or email
- Update stakeholders automatically as incident progresses

☑ 5. Reporting & Documentation

- Automatically generate post-incident reports
- Populate dashboards with key metrics (MTTR, volume, root cause)
- Document every action taken during a playbook execution

🔄 6. Repetitive & Low-Level Tasks

- IOC extraction and correlation
- Scheduling scans or forensic imaging
- Tagging and updating alerts in SIEM
- Periodic threat hunting tasks (e.g., searching IOCs across logs)

🔄 7. Playbook Automation (End-to-End)

You can automate entire workflows (playbooks) for:

- Malware infection response
- Insider threat investigation
- Data exfiltration alerts
- Failed login anomaly analysis
- Phishing simulation handling

If it's repetitive, structured, and rule-based — it can (and should) be automated in SOAR.

☐ In Summary:

SOAR and EDR

SOAR = Speed + Scale + Consistency

It helps organizations **respond to threats faster**, **reduce manual effort**, and **improve incident handling maturity**.

WILL SOAR REPLACE SIEM ?

✗ No, SOAR will not replace SIEM.

Instead, **SOAR and SIEM complement each other** in the security ecosystem.

What is a SIEM?

SIEM (Security Information and Event Management) is primarily for:

- **Collecting and aggregating logs**
- **Correlating events**
- **Generating alerts based on detection rules**
- **Historical search and compliance reporting**

Think of SIEM as the "**central brain**" for monitoring and detection across the environment

What is SOAR?

SOAR (Security Orchestration, Automation, and Response) is used to:

- **Automate response to alerts (from SIEM and other tools)**
- **Enrich, triage, and investigate faster**
- **Execute playbooks for incidents**
- **Coordinate actions across multiple tools (EDR, firewalls, ticketing, etc.)**

SOAR and EDR

SOAR is more like the **"muscle and workflow engine"** that acts on what the SIEM sees.

SIEM + SOAR = Full Visibility + Fast Action

Function	SIEM	SOAR
Log Collection	✓ Yes	✗ No
Alert Correlation	✓ Yes	✗ No
Real-Time Detection	✓ Yes	✗ No
Automation	✗ Limited	✓ Full automation
Orchestration	✗ No	✓ Yes
Incident Response	⚠ Manual/Semi-automated	✓ Automated (playbooks)

Bottom Line: A Better Place To learn

- **SIEM tells you what's happening.**
- **SOAR helps you respond faster and more efficiently.**

They are strongest **together**, especially in modern SOC's where automation is essential.



Top SOAR Vendors

1. Splunk SOAR (formerly Phantom)

- Deep integration with Splunk SIEM
- Highly customizable playbooks (Python-based)
- Strong community and app ecosystem

2. Cortex XSOAR by Palo Alto Networks

- One of the most comprehensive SOAR platforms
- Large prebuilt playbook library
- Native threat intel management and case management

3. IBM Security QRadar SOAR (formerly Resilient)

- Integrates well with QRadar SIEM
- Focused on incident response and case management
- Visual playbook designer

4. Swimlane

- Low-code/no-code playbook builder
- Strong reporting and dashboarding features
- Good for complex workflows and large-scale environments

5. Siemplify (now part of Google Chronicle)

- Lightweight and easy to use
- Combines SOAR, case management, and threat intel
- Tight integration with Google security stack

6. DFLabs IncMan SOAR (now part of Sekoia.io)

- Strong incident response capabilities
- Used by law enforcement and critical infrastructure sectors

7. Tines

- No-code automation platform
- Great for non-technical users
- Strong integrations with SaaS, DevOps, and cloud platforms

Emerging & Niche Players

- **FortiSOAR** – From Fortinet, good for FortiGate/FortiEDR environments
- **LogRhythm Axon** – Newer, integrated with LogRhythm SIEM
- **Rapid7 InsightConnect** – Part of Insight platform, easy setup for smaller teams
- **ThreatConnect** – Combines SOAR with Threat Intel Platform (TIP)

How to Choose the Right SOAR:

- Check for **integration** with your current tools (SIEM, EDR, ticketing)
 - Evaluate **playbook flexibility** and ease of use
 - Consider **scalability** and **support/community**
-

SOAR and EDR

Phishing Email Alert Automation

Step-by-Step SOAR Automation Flow

Step 1: Trigger Playbook

- The alert is ingested into SOAR from the SIEM or mailbox.
- Playbook is automatically triggered based on alert type: *Phishing Email Detected*.

Step 2: Automated Enrichment

- **Extract:**
 - Sender address
 - Subject
 - Links/URLs
 - Attachments
- **Enrich with threat intel:**
 - Check sender domain and IP reputation (VirusTotal, AbuseIPDB)
 - Sandbox URL or attachment detonation
 - WHOIS lookup on domain

Step 3: Decision Logic

- **If:**
 - Domain/IP is flagged as malicious 
 - Sandbox detonation shows malware behavior 

SOAR and EDR

- Then: Move to containment
- Else: Flag as false positive or request human review

Step 4: Containment (Automated Actions)

- Quarantine email in all user inboxes (via O365/Gmail API)
- Block URLs/domains at web proxy or firewall
- Create a ticket for incident tracking
- Disable account or force password reset (if compromise suspected)

Step 5: Documentation & Notification

- Auto-generate incident report
- Notify SOC team via Slack/Teams/Email
- Update ticket with all actions and evidence

Phishing Alert Automation with SOAR

1. Alert Triggered

(from SIEM or user report)



2. Extract Email Artifacts

- Sender email address
- Subject line
- URLs & attachments

SOAR and EDR



3. Enrich with Threat Intelligence

- VirusTotal / Threat Intel lookup on URLs/IPs
- WHOIS domain info
- Detonate attachments/URLs in sandbox



4. Decision: Is threat confirmed?



Yes	No	Maybe
	Mark as false positive & close alert	Send for human review



5a. Automated Containment (if Yes)

- Quarantine email in user inboxes
- Block malicious URLs/domains at firewall/proxy
- Force password reset or disable account (if compromised)

SOAR and EDR

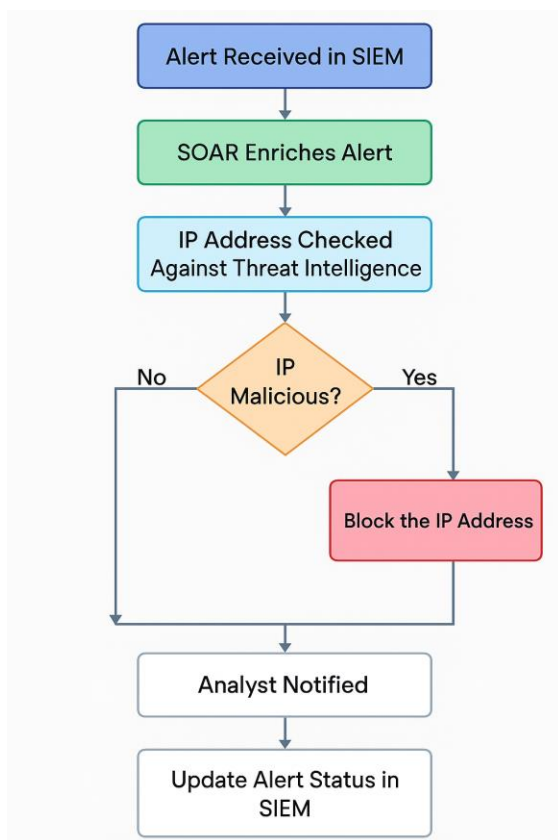
- Create and update incident ticket

↓

6. Notification & Reporting

- Notify SOC team via Slack/Teams/email
- Auto-generate incident report with all findings and actions

Visual Chart (Flow Diagram)





Core Features of Cortex XSOAR

1. Playbook-Driven Automation

- **Automated incident response workflows** using visual playbooks.
- Drag-and-drop UI to build complex logic without writing code.
- Supports conditions, loops, timers, human approvals, and more.

2. Case Management

- Centralized incident management console.
- Tracks all incident data, timeline, tasks, and analyst actions.
- Role-based access and collaboration for teams.

3. Threat Intelligence Management (TIM)

- Ingests threat intel feeds (STIX, TAXII, MISP, etc.).
- Correlates IOCs with incidents in real-time.
- De-duplication and scoring of indicators.
- Threat intel sharing and enrichment.

4. Threat Hunting

- Run hunting queries across integrated tools (EDR, SIEM, etc.).
- Automate threat hunting based on IOCs, behaviors, and anomalies.

SOAR and EDR

5. Incident Enrichment

- Automatically enrich alerts with data from:
 - VirusTotal
 - Whois
 - Geolocation
 - Internal systems (AD, EDR, CMDB)

6. Integrations

- 800+ out-of-the-box integrations:
 - SIEM (Splunk, QRadar, etc.)
 - EDR (CrowdStrike, Cortex XDR, etc.)
 - Ticketing (ServiceNow, Jira)
 - Threat Intel (VirusTotal, MISP)
 - Firewalls, cloud, and more

R&K InfoTech
A Better Place To learn

7. War Room

- Real-time collaboration environment per incident.
- Chat, evidence collection, and command execution.
- Track changes and decisions made during investigation.

8. Custom Dashboards & Reporting

- Build dashboards with KPIs, SLA tracking, response times.
- Automated reporting to stakeholders.

9. Machine Learning Recommendations

- Suggests playbooks and actions based on historical incidents.
- Identifies commonly used responses and patterns.

10. Multi-Tenant Architecture

- Ideal for MSSPs or large enterprises with separate business units.
- Allows isolated data and workflows per tenant.



Example Use Cases

- Phishing alert triage & response (auto-closing false positives)
- Malware investigation with file hash enrichment and EDR containment
- Privilege abuse detection with automated user logout
- IOC correlation from threat feeds across enterprise logs

R&K InfoTech

A Better Place To learn



What is EDR (Endpoint Detection and Response)?

EDR (Endpoint Detection and Response) is a cybersecurity technology that provides continuous monitoring and response capabilities for **endpoint devices** such as laptops, desktops, and servers.



Why EDR is Important

In modern cyberattacks, endpoints are a **primary target**. Traditional antivirus tools often miss sophisticated threats like fileless malware, ransomware, or advanced persistent threats (APTs). EDR bridges that gap with **real-time visibility**, **intelligent detection**, and **automated responses**.

□ Key Features of EDR

1. Real-time Monitoring

- Continuously watches all endpoint activities: process creation, file access, network connections, registry changes, etc.

2. Threat Detection

- Uses **behavior-based** and **signature-based** techniques to detect:
 - Malware
 - Ransomware
 - Privilege escalation
 - Suspicious lateral movement

3. Incident Response

- Allows security teams to:
 - Kill malicious processes

SOAR and EDR

- Isolate infected endpoints from the network
- Delete malicious files
- Initiate forensic data collection

4. Threat Hunting

- Analysts can query endpoint data to proactively look for signs of compromise.
- Supports complex queries (like MITRE ATT&CK mapping).

5. Forensics and Investigation

- Stores historical data for deep analysis.
- Helps reconstruct attack chains (TTPs) using timeline views.

□ Popular EDR Tools

- **CrowdStrike Falcon**
- **Microsoft Defender for Endpoint**
- **SentinelOne**
- **Sophos Intercept X**
- **Trend Micro Apex One**
- **Palo Alto Cortex XDR** (EDR + XDR functionality)

🌀 Example Scenario

Use Case: A user unknowingly downloads a malicious file from a phishing email.

Without EDR:

- Antivirus misses the threat.

SOAR and EDR

- Malware spreads laterally.
- Data gets exfiltrated without detection.

With EDR:

1. Suspicious behavior (like PowerShell script spawning) is detected.
2. Alert generated, endpoint automatically isolated.
3. SOC team investigates using EDR timeline and memory dumps.
4. Malware is removed, and the device is restored securely.

Summary

Feature	EDR
Focus	Endpoint security (detection & response)
Strength	Deep visibility, quick response, threat hunting
Replaces	Traditional antivirus & basic endpoint protection
Required By	Modern SOC teams & cybersecurity frameworks (e.g., MITRE, NIST)

How Does EDR Work?

EDR (Endpoint Detection and Response) works by continuously monitoring endpoint activities and providing tools to detect, investigate, and respond to threats **in real time**.

Step-by-Step Working of EDR

SOAR and EDR

1. Continuous Monitoring

EDR agents are installed on endpoints (laptops, desktops, servers) and monitor:

- File executions
- Registry changes
- Network connections
- Processes and memory
- Login attempts and behavior anomalies

2. Data Collection

The EDR agent collects **telemetry data** and sends it to a central EDR platform (cloud or on-premises) for analysis.

3. Detection

Using:

- **Signature-based detection** (known threats)
- **Behavior-based analysis** (suspicious activity patterns)

- **Machine Learning models**

it detects both known and unknown threats like:

- Malware
- Fileless attacks
- Privilege escalation
- Lateral movement

4. Alerting

SOAR and EDR

If suspicious activity is found, it **raises alerts** with detailed context:

- What happened
- When
- On which endpoint
- What was affected

5. Response & Remediation

Security analysts or automation rules can:

- **Isolate the endpoint** from the network
- **Kill malicious processes**
- **Delete suspicious files**
- **Roll back changes** (some EDRs like CrowdStrike or SentinelOne)
- **Trigger playbooks** for further action

6. Investigation & Threat Hunting

SOC analysts can **dig deep** into:

- Event timelines
- Process trees
- Network connections
to identify root cause, attacker techniques (mapped to MITRE ATT&CK), and affected assets.

How is EDR Related to SOC?

 EDR = Eyes and Ears of a SOC on Endpoints

SOAR and EDR

Here's how they work together:

EDR Role	SOC Function
Detects suspicious endpoint behavior	Receives and triages alerts
Provides rich telemetry and logs	Investigates incidents using EDR dashboards
Enables remote response (isolation, remediation)	Executes containment actions
Supports threat hunting across endpoints	Analysts proactively search for threats
Sends alerts to SIEM/SOAR	SOC correlates with other data sources (firewall, email, network)

□ Real-World Example

Scenario: A malicious Excel file with a macro gets opened.

- **EDR** notices a child PowerShell process spawned by Excel → flags suspicious behavior.
- Sends an alert to the **SOC**.
- **SOC Analyst** investigates using the EDR console:
 - Sees the file, user, and behavior chain.
 - Finds it connected to a malicious IP.
- Analyst **isolates the endpoint** and deletes the file via EDR.
- SOC uses **SIEM** to check for lateral movement or similar activity across the network.

□ Summary

- ✓ EDR provides **detection, investigation, and response** at the endpoint level.
 - ✓ The **SOC uses EDR** as a frontline tool to monitor and protect endpoints.
 - ✓ Together, they enable **faster response, better visibility, and reduced risk**.
-

🔍 Step-by-Step: Detect & Respond to Malware Using EDR

🔔 Step 1: Alert Triggered

- A malware alert is triggered by the EDR agent (e.g., SentinelOne, CrowdStrike, Defender for Endpoint).
- Alert types may include:
 - Malicious file execution
 - Command & control connection
 - Process injection
 - Known malware signature match
 - Suspicious behavior chain (e.g., Word > PowerShell)

EDR provides metadata like:

- File hash
- Process tree

SOAR and EDR

- Device name
 - User name
 - File path
 - Alert severity
-

Step 2: Triage the Alert

- **Check the alert details:**
 - Severity: Critical, High, Medium
 - MITRE ATT&CK mapping (e.g., T1059 – Command Scripting)
 - Was the file quarantined or blocked?
 - **Analyze the Process Tree:**
 - Understand how the malware executed (e.g., parent → child → network activity)
 - Check for privilege escalation or lateral movement
-

Step 3: Investigate the Malware

Use the EDR console to:

- **Check file hash reputation** using VirusTotal, Any.run, or internal TI.
- **Check user activity:**
 - Was this run via RDP or local login?

SOAR and EDR

- **Review process behavior:**
 - Did it create persistence (e.g., run keys, scheduled task)?
 - Did it disable security tools or modify registry keys?
- **Look for Indicators of Compromise (IOCs) like:**
 - File names
 - IPs
 - Domains

Step 4: Respond to the Threat

EDR tools allow direct response actions:

Action	Description
 Isolate Endpoint	Cuts the device off from the network (except EDR comms)
 Kill Process	Stops the malicious process immediately
 Delete File	Removes the detected malicious file
 Quarantine	Moves the file to a secure location
 Rollback Changes (if supported)	Reverses registry/file changes made by malware (e.g., SentinelOne)

Step 5: Hunt for Spread

- Use EDR to **search across all endpoints:**
 - Who else has this file hash?

SOAR and EDR

- Who connected to the same domain/IP?
 - Did the malware spread via USB, file shares, or credentials?
 - **Run IOC sweep** using file hashes or command line patterns.
-

Step 6: Document & Close

- Document:
 - Malware type and behavior
 - Systems/users affected
 - Actions taken (isolated, removed, scanned)
 - Final status (contained, eradicated)
 - Create incident report or SOAR ticket
 - Submit sample to Threat Intel team if needed
-

Example Case

Alert: Suspicious executable detected on HR-PC01

Details:

- Process: invoice_viewer.exe → powershell.exe
- Outbound to 198.51.100.12:443

Response:

1. EDR quarantines file automatically (auto-response).
2. Analyst isolates endpoint manually.

SOAR and EDR

3. Malware hash submitted to VirusTotal → confirmed Trojan.
4. Sweep shows same hash on 2 more endpoints.
5. Containment + deletion + scan + password reset initiated.

✓ Summary

Phase	Tool (EDR) Helps You To:
Detect	Real-time alerts, behavioral analysis
Investigate	Process tree, user actions, file/network analysis
Respond	Kill, quarantine, isolate, rollback
Hunt	IOC search, hash/domain sweeps
Report	Document findings, create tickets

□ What is Malware Behavior?

Malware behavior refers to the **sequence of actions** performed by malicious software after it infiltrates a system. Instead of just matching static signatures, modern detection tools like EDR/SIEM/Sandbox analyze these behaviors to identify and stop threats in real time.

🔑 Key Phases of Malware Behavior:

1. Initial Access

- **Method of Entry:**
 - Phishing email with attachment or link

SOAR and EDR

- Malicious USB device
- Drive-by download (web exploit)
- Remote desktop protocol (RDP) brute force
- **Common Indicators:**
 - Email from spoofed sender
 - Unexpected download from browser
 - Unknown login attempts

2. Execution

- **The malware payload is executed** (manually or automatically).
- **Examples:**
 - invoice.doc drops and executes a macro script
 - A *.exe file spawns PowerShell
- **Tools Used:**
 - Windows Script Host
 - PowerShell
 - cmd.exe
- **Behavior Indicators:**
 - Suspicious child processes (e.g., Word > PowerShell)
 - Unusual command-line arguments

3. Persistence

- The malware tries to **stay in the system even after a reboot.**

SOAR and EDR

- **Techniques:**

- Modifying registry keys (e.g., Run, RunOnce)
- Creating scheduled tasks
- Dropping startup scripts

- **Why It Matters:**

- Without persistence, malware dies on reboot.

4. Privilege Escalation

- Attempts to gain **admin or SYSTEM-level privileges**.

- **Techniques:**

- Exploiting unpatched software
- Token impersonation
- UAC bypass

- **Indicators:**

- whoami /priv or use of exploits like CVE-2021-34527

5. Defense Evasion

- **Goal:** Avoid detection by antivirus or EDR.

- **Methods:**

- Code obfuscation
- DLL sideloading
- Disabling security tools via script

- **Indicators:**

SOAR and EDR

- Tampering with Defender settings
- Adding exclusions to AV

6. Credential Access

- **Harvests stored or typed credentials**
- **Techniques:**
 - Keylogging
 - LSASS dumping (e.g., using Mimikatz)
 - Clipboard monitoring
- **Indicators:**
 - Access to lsass.exe
 - Files with captured keystroke

7. Lateral Movement

- **Spreads across the network** to infect more systems.
- **Methods:**
 - Using stolen credentials
 - SMB/PSEXEC/WMI
- **Indicators:**
 - Remote logins
 - Connections to multiple internal hosts

8. Command & Control (C2)

- **Connects to attacker's server** to receive commands.

SOAR and EDR

- **Protocols:** HTTP, HTTPS, DNS tunneling, IRC
- **Indicators:**
 - Communication with unknown IPs/domains
 - Encrypted outbound traffic to rare countries

9. Data Exfiltration / Payload Action

- **Exfiltrates sensitive data or takes destructive action**
- **Examples:**
 - Sends data to external server
 - Encrypts files (ransomware)
 - Deletes backups/logs
- **Indicators:**
 - Uploading large data over HTTPS
 - .locked or .encrypted file extensions
 - Files deleted from backup drives

10. Impact

- **Final goal of the malware is achieved:**
 - System damage
 - Business disruption
 - Financial loss
 - Ransomware note or DDoS initiated

SOAR and EDR

Behavior Type	Tools/Commands	MITRE ATT&CK Tactic
File Drop	cmd, powershell, certutil	Execution
Auto Start	Registry Run keys, schtasks	Persistence
Defense Evasion	AV tampering, obfuscation	Defense Evasion
Credential Dump	Isass.exe, mimikatz	Credential Access
Network Spread	Psexec, SMB, RDP	Lateral Movement
Exfiltration	FTP, HTTPS, cloud storage	Exfiltration

□ Bonus Tip: Why This Matters in the SOC

Understanding behavior helps SOC teams:

- Detect **fileless malware** (behavior-based > signature-based)
- Recognize **lateral movement** early
- Prioritize alerts with **MITRE ATT&CK mapping**
- Strengthen detection rules in SIEM/EDR

□ Key Features of Microsoft Defender for Endpoint

1. Threat & Vulnerability Management (TVM)

- Real-time vulnerability discovery
- Risk-based prioritization
- Integration with patch management tools (like Intune, SCCM)

2. Attack Surface Reduction (ASR)

- Helps reduce exploitable entry points

SOAR and EDR

- Uses rules to:
 - Block executable content from email/web
 - Prevent Office macros from untrusted sources
 - Control application behavior (e.g., script-based attacks)

3. Endpoint Detection and Response (EDR)

- Detects suspicious behaviors and advanced threats
- Provides detailed **incident timelines**
- Supports **deep investigation and hunting**
- Allows **response actions**: isolate device, kill process, collect forensics, etc.

4. Automated Investigation & Remediation (AIR)

- Uses AI and rules to **automatically analyze and remediate alerts**
- Reduces SOC analyst workload
- Auto-remediation actions include:
 - Stopping malicious processes
 - Quarantining files
 - Removing registry entries

5. Threat Hunting (Advanced Hunting)

- Powerful Kusto Query Language (KQL)-based interface
- Query telemetry from:
 - Device behavior

SOAR and EDR

- Network activity
- User actions
- Enables proactive threat detection

6. Endpoint Behavioral Sensors

- Continuously collect and send telemetry data
- Includes process creation, registry changes, memory activities, etc.

7. Microsoft Threat Intelligence

- Uses Microsoft's global threat database
- Provides real-time intelligence on attacker tools, IPs, malware families

8. Secure Score for Devices

- Security posture metric
- Recommends actionable steps to improve endpoint security

9. Integration with Microsoft 365 Defender

- Unified visibility across:
 - **Email** (Defender for Office 365)
 - **Identities** (Defender for Identity)
 - **Cloud apps** (Defender for Cloud Apps)
- Facilitates **cross-domain correlation** and **XDR investigations**

10. Device Inventory and Tagging

- View all onboarded devices

SOAR and EDR

- Tag devices by function, location, sensitivity, etc.

11. Live Response

- Remotely access the compromised endpoint via a command-line interface
- Perform actions like:
 - Collecting logs
 - Killing processes
 - Running scripts

12. Integration with SIEM/SOAR

- Integrates with:
 - Microsoft Sentinel
 - Other third-party SIEMs (Splunk, QRadar)
- Supports alert forwarding, incident correlation, and automated playbooks

Summary Table

Component	Purpose
TVM	Risk-based vulnerability management
ASR	Reduce attack surface via rules
EDR	Behavioral-based detection and response
AIR	Auto analysis/remediation of threats
Advanced Hunting	Proactive, custom threat detection via KQL

SOAR and EDR

Component	Purpose
Threat Intelligence	Microsoft-sourced threat context and indicators
Secure Score	Endpoint hardening recommendations
Microsoft 365 Defender	Unified XDR across email, identity, devices
SIEM/SOAR Integration	Alerts & automation across platforms
Live Response	Remote CLI-based investigation and control

□ Step-by-Step: Monitoring & Analyzing Alerts in MDE

◆ 1. Access the Security Portal

- Go to: <https://security.microsoft.com>
- Navigate to “**Incidents & Alerts**” under the **Microsoft 365 Defender** dashboard.

◆ 2. Review the Alerts Dashboard

- The dashboard gives you:
 - **Severity levels** (Low, Medium, High)
 - **Number of impacted devices/users**
 - **Status** (New, Active, Resolved)
 - **Detection source** (EDR, TVM, ASR, etc.)

👉 Focus first on **High Severity** and **Active** alerts.

◆ 3. Drill Down into an Alert

Click on any alert to open the **alert detail pane**, which includes:

SOAR and EDR

- **Title** (e.g., “Suspicious PowerShell command executed”)
- **Tactic & Technique** (MITRE ATT&CK mapping)
- **Detection source** (AV, EDR, ASR, etc.)
- **Time of detection**
- **Affected device and user**

◆ 4. Use the Incident Page (Correlated Alerts)

- MDE often **groups multiple related alerts** into a single **incident**.
- You can view:
 - **Attack timeline**
 - **All devices and users involved**
 - **Associated alerts and evidence**
 - **Response actions taken or suggested**

◆ 5. Analyze Alert Evidence

Look for evidence like:

- **Process command lines**
- **File hash and path**
- **Registry and service modifications**
- **Network connections (IPs, domains)**
- **Parent-child process chains**

□ **Key analysis tip:** Check if the behavior is normal for that user or device.

◆ 6. Check Device Timeline

- Go to **“Device Inventory”** → **select device** → **Timeline**
- See a **chronological list** of system events:
 - Process execution
 - File and registry changes
 - Network connections
 - Logon sessions

Use filters to narrow down to the time of alert.

◆ 7. Run Advanced Hunting (Optional but Powerful)

- Use **KQL (Kusto Query Language)** to:
 - Search for indicators (hashes, domains, IPs)
 - Find similar activity across the organization
 - Detect lateral movement or persistence

Example KQL:

DeviceProcessEvents

| where FileName == "powershell.exe"

| where ProcessCommandLine contains "EncodedCommand"

◆ 8. Take Response Actions

From the alert or device page, you can:

- **Isolate device** from the network (except MDE communication)
- **Collect investigation package**

SOAR and EDR

- **Run antivirus scan**
- **Kill process / quarantine file**
- **Initiate live response session**

◆ 9. Document Findings

Add notes to the alert or incident:

- Root cause (phishing, exploit, insider, etc.)
- Actions taken (isolated, remediated, informed user)
- Preventive steps (ASR rule added, patch applied)

◆ 10. Close or Escalate

- If resolved, mark the alert as **“Resolved - True Positive”**
- If it’s a false alarm, choose **“False Positive”** and provide a reason
- Escalate to higher-tier SOC or Incident Response team if needed

☑ Summary Table

Task

Where to Perform

View Alerts & Incidents Incidents & Alerts dashboard

Investigate Timeline Device → Timeline

Threat Hunting Advanced Hunting tab (KQL)

Response Actions Device/Alert → Action Center

Documentation Notes inside alert/incident pane

Closure/Escalation Alert status & tagging

SOAR and EDR

🔍 EDR vs MDR vs XDR – Quick Comparison

Feature / Aspect	EDR (Endpoint Detection & Response)	MDR (Managed Detection & Response)	XDR (Extended Detection & Response)
Definition	Security solution focused on detecting & responding to threats on endpoints (laptops, servers, etc.)	A service that provides threat detection, response, and monitoring by a third-party SOC	An integrated platform that correlates data across multiple security layers (email, endpoint, cloud, etc.)
Who manages it?	In-house SOC team	Third-party (vendor/SOC as a Service)	Typically in-house or vendor-supported
Data sources	Endpoint only	Endpoint + possibly others depending on service	Endpoint, Email, Identity, Cloud, Network, etc.
Scope	Limited to endpoint activity (processes, files, registry, etc.)	Broader, depending on provider — includes EDR + human expertise	Broadest — native integration across multiple security layers
Threat Detection	Behavior-based, signature-based	Enhanced by human expertise + threat intel	AI/ML + cross-platform telemetry correlation
Threat Hunting	Analyst-driven (manual)	Performed by vendor's SOC	Built-in + customizable
Response Capabilities	Isolate device, kill process, collect forensics	Same as EDR, plus proactive response and 24/7 coverage	Automated + orchestrated response across layers
Resource Requirement	Requires skilled internal team	Minimal — outsourced service	Moderate — in-house or hybrid team needed
Cost	Medium	High (service-based pricing)	Medium to High (platform + team)
Examples	Microsoft Defender for Endpoint, CrowdStrike Falcon, SentinelOne	Arctic Wolf, CrowdStrike MDR, Red Canary, Sophos MDR	Microsoft 365 Defender (XDR), Palo Alto Cortex XDR, Trend Micro XDR

□ When to Use What?

SOAR and EDR

- **Use EDR if:**
 - You have a skilled internal SOC team
 - You need deep visibility into endpoints only
- **Use MDR if:**
 - You lack an internal SOC or threat hunters
 - You want 24/7 monitoring and expert response
- **Use XDR if:**
 - You want unified threat detection across multiple sources (email, endpoints, identity, cloud)
 - You want to reduce alert fatigue through correlation
 - You already use a suite like Microsoft 365 Defender or Palo Alto Cortex



Real-World Example

Scenario

Recommended Tool

Malware detected on one laptop → analyze spread →
block file

EDR

Small company with no SOC team, wants full-time
protection

MDR

Spear phishing → credential theft → lateral movement →
data exfiltration

XDR